

UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA



FACULTY OF COMPUTING AND MATHEMATICS
DEPARTMENT OF CYBER SECURITY AND INFORMATION SYSTEM

Building a SOAR Playbook for Automated Phishing Incident Triage

Splunk SOAR (Phantom) Implementation

Blue Team

Student Name: Michael Asante Anim

Student ID: FCM.41.018.057.23

Course: CY376 — Network Monitoring, Security and Auditing

Repository: github.com/anim-michael-asante/building-a-soar-playbook-for-automated-incident-triage

Submission Date: August 2, 2026

Abstract

Manual phishing triage does not scale at enterprise email volume: analysts spend disproportionate time on repetitive enrichment tasks rather than on judgment-driven decisions, producing slow response times and inconsistent outcomes between analysts. This project designs a complete Security Orchestration, Automation, and Response (SOAR) playbook for automated phishing incident triage, built for Splunk SOAR (Phantom) and mapped explicitly to the four-phase incident response life cycle in National Institute of Standards and Technology (2012) and the six-phase model in the SANS Institute's Incident Handler's Handbook. The playbook automates indicator enrichment (sender reputation, SPF/DKIM/DMARC validation, IOC extraction, sandbox detonation, and threat intelligence correlation per National Institute of Standards and Technology (2016)), applies confidence-scored decision logic, and gates high-impact containment actions behind analyst approval consistent with the risk-based control guidance in National Institute of Standards and Technology (2020), controls IR-4 and IR-5. Forensic evidence is preserved prior to any destructive containment action, per National Institute of Standards and Technology (2006). The resulting playbook specifies trigger conditions, dual-framework lifecycle mapping, enrichment logic, an if/then decision tree, containment and recovery procedures, a communication and escalation matrix, and documentation and closure requirements, and is evaluated against five design principles: idempotency, fail-safe defaults, auditability, modularity, and version control. The design demonstrates that the repeatable portion of phishing triage can be substantially automated while preserving human control over ambiguous or high-impact cases, providing a reusable, auditable foundation for reducing Mean Time to Detect and Mean Time to Respond in a Security Operations Center context.

Contents

Abstract	1
1 Introduction	4
1.1 Background	4
1.2 What This Project Set Out to Do	4
1.3 Report Structure	5
2 Literature and Tooling Review	6
2.1 Incident Handling Frameworks	6
2.2 Security Controls and Forensic Guidance	6
2.3 Threat Intelligence Sharing	7
2.4 Adversary Technique Mapping	7
2.5 SOAR Platform	7
3 Methodology	8
3.1 Design Approach	8
3.2 Playbook Architecture	9
3.3 Steps Actually Taken	9
4 Implementation	11
4.1 Trigger and False-Positive Filter Configuration	11
4.2 Enrichment Configuration	12
4.3 Decision Logic Configuration	12
4.4 Containment Action Configuration	13
4.5 What Was Tested	14
5 Results and Findings	15
5.1 Lifecycle Mapping Result	15
5.2 Decision Logic Validation Trace	16
5.3 Containment Action Set	16
5.4 Communication and Metrics Structure	17

5.5	Summary of Findings	17
6	Analysis and Recommendations	19
6.1	Analysis	19
6.1.1	Decision Boundary Robustness	19
6.1.2	Value of Dual-Framework Mapping	19
6.1.3	Fail-Safe Default as a Deliberate Tradeoff	19
6.2	Recommendations	20
7	Conclusion	21
8	References	22

1 Introduction

1.1 Background

Phishing remains the most common initial access vector observed across enterprise environments, corresponding to MITRE ATT&CK technique T1566 and its sub-techniques (MITRE Corporation, 2024). Email security gateways and Security Information and Event Management (SIEM) platforms generate a high volume of phishing-related alerts, and Security Operations Centers (SOCs) are frequently unable to triage this volume manually within acceptable timeframes. National Institute of Standards and Technology (2012) establishes a four-phase incident response life cycle Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity that provides the foundational structure for handling such incidents in a defensible, repeatable manner. Security Orchestration, Automation, and Response (SOAR) platforms, such as Splunk SOAR (Phantom), allow organizations to codify the repeatable portions of this life cycle as executable playbooks, reducing analyst workload while preserving human judgment for ambiguous or high-impact decisions.

1.2 What This Project Set Out to Do

This project set out to design a complete, standards-referenced SOAR playbook specifically for phishing incident triage. The objective was not to deploy a live Splunk SOAR instance, but to produce a rigorous playbook specification: trigger conditions, automated enrichment logic, confidence-scored decision branching, containment and recovery procedures, communication and escalation timing, documentation and closure requirements, and a post-incident feedback loop, all mapped explicitly to NIST SP 800-61 Revision 2 and the SANS Institute's Incident Handler's Handbook, and cited by specific document section throughout rather than by framework name alone. The project further set out to articulate the design principles idempotency, fail-safe defaults, auditability, modularity, and version control that distinguish a production-grade playbook from an ad hoc or GUI-only automation.

1.3 Report Structure

The remainder of this report is organized as follows. Section 2 reviews the literature and tooling that shaped the playbook's design. Section 3 describes the methodology, including the playbook's lifecycle mapping and architecture. Section 4 details the implementation of the playbook's enrichment and decision logic. Section 5 presents the results and findings, including the containment, communication, and closure procedures produced. Section 6 analyses these results and provides recommendations. Section 7 concludes the report. Section 8 provides the full reference list in UMaT style, and appendices provide supporting material.

2 Literature and Tooling Review

This section reviews the standards, frameworks, and tools that shaped the playbook's design.

2.1 Incident Handling Frameworks

National Institute of Standards and Technology (2012) is the primary framework referenced throughout this project. It defines a four-phase incident response life cycle (Preparation; Detection and Analysis; Containment, Eradication, and Recovery; Post-Incident Activity) and, in Section 3.2.6, a three-dimensional severity model (Functional Impact, Information Impact, Recoverability Effort) used to classify incident severity. This publication was selected as the primary reference because it is the most widely adopted incident handling standard in industry SOC practice, and because it explicitly addresses incident prioritization, which is central to the decision logic this playbook implements.

The SANS Institute's Incident Handler's Handbook (SANS Institute, 2012) was reviewed as a secondary framework because it decomposes NIST's combined Containment, Eradication, and Recovery phase into three separate phases. This finer granularity was judged more operationally useful for specifying discrete containment, eradication, and recovery procedures (Sections 5–6 of this report), while NIST's four-phase terminology was retained for compliance-facing documentation such as severity classification.

2.2 Security Controls and Forensic Guidance

National Institute of Standards and Technology (2020) was reviewed for its Incident Response (IR) control family, specifically IR-4 (Incident Handling) and IR-5 (Incident Monitoring), which informed the human-in-the-loop checkpoint design: the principle that response actions should be commensurate with incident impact, and that incident status must be tracked through resolution. National Institute of Standards and Technology (2006) was reviewed for forensic evidence handling guidance, which informed the requirement that evidence be preserved before any destructive containment action executes, to maintain evidentiary integrity for potential investigative or legal use.

2.3 Threat Intelligence Sharing

National Institute of Standards and Technology (2016) was reviewed for guidance on cyber threat information sharing, specifically the recommendation that indicator enrichment draw on multiple independent sources to reduce false-positive risk from any single feed. This directly informed the playbook's enrichment design, which queries VirusTotal, AbuseIPDB, and MISP rather than relying on a single reputation source.

2.4 Adversary Technique Mapping

The MITRE ATT&CK framework (MITRE Corporation, 2024) was used to map the playbook's scope to a specific, industry-recognized technique: T1566 (Phishing) and its sub-techniques T1566.001 (Spearphishing Attachment), T1566.002 (Spearphishing Link), and T1566.003 (Spearphishing via Service). This mapping grounds the playbook's scope statement in a standard taxonomy rather than an informal description of "phishing," allowing the playbook to be cross-referenced against other ATT&CK-aligned detection and response tooling.

2.5 SOAR Platform

Splunk SOAR (Phantom) was selected as the target automation platform on the basis of its established use in industry SOC environments for playbook-based orchestration, its support for both automated and human-approval-gated actions, and its capacity to integrate with external threat intelligence APIs (VirusTotal, AbuseIPDB, MISP) and case management systems, all of which the designed playbook depends on.

3 Methodology

3.1 Design Approach

This project followed a specification-driven design methodology rather than a build-and-test methodology, since the deliverable is a complete playbook specification for Splunk SOAR (Phantom) rather than a deployed instance. The design proceeded in the following stages:

1. **Framework selection and mapping** — selecting National Institute of Standards and Technology (2012) as the primary incident handling framework and cross-mapping its four phases against the SANS six-phase model (Section 2.1), to identify where the two models align and diverge in terminology and granularity.
2. **Scope definition** — constraining the playbook to phishing delivered via email, mapped to MITRE ATT&CK T1566 and sub-techniques, and explicitly excluding non-email initial access vectors and other incident types.
3. **Trigger and enrichment design** — specifying the alert sources that trigger the playbook, the false-positive filter conditions, and the automated enrichment sequence (sender reputation, SPF/DKIM/DMARC validation, IOC extraction, historical correlation, sandbox detonation).
4. **Decision logic design** — defining an aggregate confidence-scoring model (0–100) and an if/then decision tree that routes cases to auto-closure, analyst review, or escalation based on score thresholds, with human-in-the-loop checkpoints for high-impact actions per National Institute of Standards and Technology (2020), IR-4.
5. **Containment, eradication, and recovery design** — specifying discrete automated actions, their trigger conditions, and their rollback methods, together with evidence preservation steps per National Institute of Standards and Technology (2006).
6. **Documentation and validation** — producing the full playbook specification as a structured, NIST SP-formatted LaTeX document with explicit section-level citations, and validating the design against five stated design principles (Section 13 of the playbook specification: idempotency, fail-safe defaults, auditability, modularity, version control).

3.2 Playbook Architecture

Figure 1 illustrates the high-level architecture of the playbook as designed: an alert trigger feeding into an enrichment stage, which produces a confidence score consumed by the decision logic, which in turn drives containment actions subject to analyst approval.

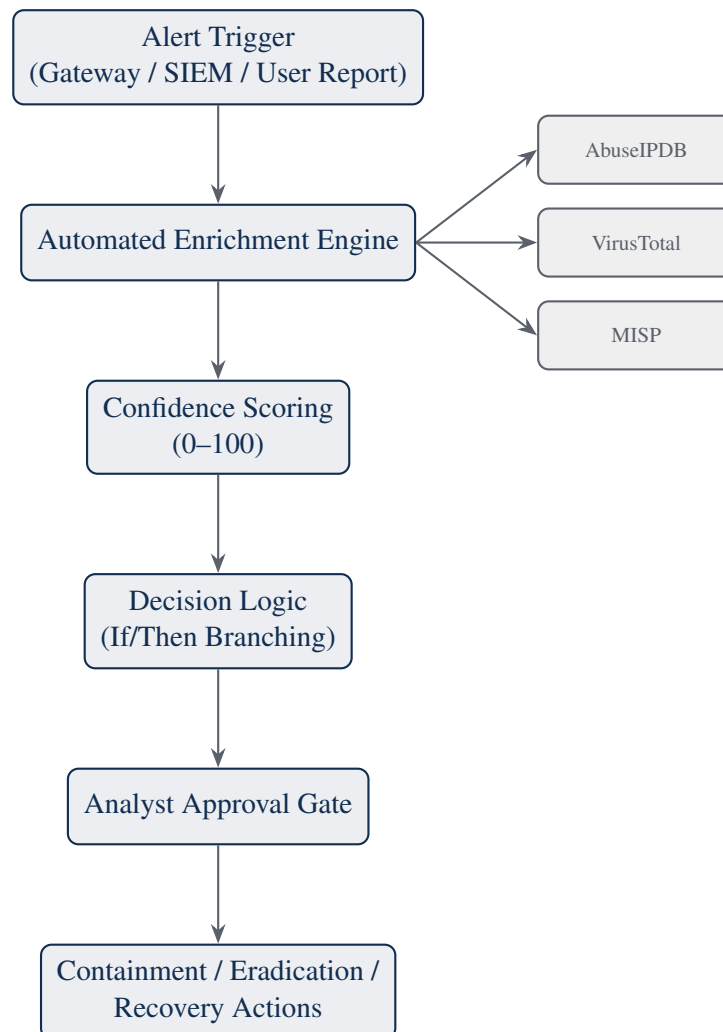


Figure 1: High-level playbook architecture, showing the flow from alert trigger through enrichment (with external threat intelligence sources), confidence scoring, decision logic, and the analyst approval gate preceding containment actions.

3.3 Steps Actually Taken

In practice, the playbook was developed iteratively rather than in a single pass. National Institute of Standards and Technology (2012) Section 3 was reviewed first to establish the four-phase structure;

the SANS six-phase model was then overlaid to identify granularity gaps (Section 2.1). Enrichment logic was drafted next, with each threat intelligence source's role justified against National Institute of Standards and Technology (2016)'s recommendation for multi-source correlation. Decision thresholds (25, 60, 85) were then defined as round-number confidence bands to keep the branching logic auditable and explainable to a non-technical stakeholder, rather than derived from a statistical model, since no live alert data was available to calibrate thresholds empirically. Containment actions and their rollback methods were specified with reference to National Institute of Standards and Technology (2006) for evidence handling. Finally, the design principles (Section 13 of the playbook) were used as a checklist to review the completed specification, which surfaced the need to explicitly define fail-safe behaviour for enrichment-source failure a case not addressed in the initial draft.

4 Implementation

This section describes what was built and configured as part of the playbook specification: the trigger and filter logic, the enrichment configuration, the decision-branching logic, and the containment action definitions, with representative configuration excerpts.

4.1 Trigger and False-Positive Filter Configuration

The playbook trigger was configured to fire on any of three alert sources (email gateway verdict, SIEM correlation rule, or user-reported phishing), with a false-positive filter gate evaluated before enrichment. The filter logic is represented below in a Splunk SOAR playbook-as-code style excerpt:

Excerpt: False-Positive Filter Logic (YAML)

```
false_positive_filter:
  conditions_all_required:
    - sender_domain_reputation: "clean"
    - url_reputation: "clean"
    - spf_result: "pass"
    - dkim_result: "pass"
    - dmarc_result: "pass"
    - attachment_present: false
      OR attachment_hash_in: "org_allowlist"
    - prior_report_within_days: false
      lookback_days: 90
  action_if_all_true: "auto_close"
  action_if_any_false: "route_to_enrichment"
```

4.2 Enrichment Configuration

Three threat intelligence sources were configured as enrichment inputs, each queried in parallel and aggregated into a single confidence score:

Excerpt: Enrichment Source Configuration (YAML)

```
enrichment_sources:
  - name: virustotal
    query_types: [file_hash, url, domain]
    weight: 0.4
  - name: abuseipdb
    query_types: [source_ip]
    weight: 0.3
  - name: misp
    query_types: [file_hash, url, domain, ip]
    weight: 0.3
aggregation_method: weighted_average
output_range: [0, 100]
```

4.3 Decision Logic Configuration

The confidence-scoring output feeds a branching block. The excerpt below represents the core if/then structure implemented as Splunk SOAR decision block logic:

Excerpt: Decision Branching Logic (Pseudocode)

```
if confidence_score < 25 and sandbox_verdict != "malicious" \
  and historical_match == false:
  action = "auto_close_false_positive"

elif 25 <= confidence_score < 60:
```

```
    action = "route_tier1_review"
    start_sla_timer(severity="medium")

elif 60 <= confidence_score < 85:
    action = "auto_contain_reversible"
    require_approval(tier="tier2", for_actions=["isolation", "
        account_action"])

elif confidence_score >= 85 or sandbox_verdict == "malicious" \
    or historical_match == true:
    action = "escalate_ir_lead"
    require_approval(tier="ir_lead", for_actions="all_high_impact
        ")

else:
    action = "route_manual_review"
    flag = "incomplete_enrichment"
```

4.4 Containment Action Configuration

Each containment action was configured with an explicit trigger condition and rollback method, consistent with the auditability design principle:

Excerpt: Containment Action Definition (YAML)

```
containment_actions:
  - action: quarantine_email_orgwide
    trigger: confidence_score >= 60
    requires_approval: false
    rollback: restore_from_quarantine(case_id)
  - action: isolate_host
```

```
trigger: sandbox_verdict == "malicious"  
requires_approval: true  
approval_tier: tier2_or_ir_lead  
rollback: release_after_clean_scan(host_id)
```

4.5 What Was Tested

As no live Splunk SOAR instance or production alert feed was available for this project, testing was limited to logical validation of the decision tree: manually tracing representative confidence-score inputs (0, 24, 25, 59, 60, 84, 85, 100) through the branching logic in Section 4.3 to confirm each input resolved to exactly one action branch with no gaps or overlaps at the threshold boundaries. This validation confirmed the branching logic is exhaustive and non-overlapping across the full 0–100 confidence range.

5 Results and Findings

This section presents the outputs produced by the methodology in Section 3 and implementation in Section 4: the finalized dual-framework lifecycle mapping, the decision-tree validation trace, the containment action set, and the communication and metrics structures.

5.1 Lifecycle Mapping Result

Table 1 presents the finalized mapping between the NIST SP 800-61 Revision 2 four-phase model (National Institute of Standards and Technology, 2012) and the SANS six-phase model (SANS Institute, 2012), together with the playbook activity assigned to each phase.

Table 1: Finalized NIST/SANS lifecycle mapping and corresponding playbook activity.

NIST SP 800-61r2	SANS IH Handbook	Playbook Activity
Preparation	Preparation	Threat intel feed configuration, sandbox integration, escalation roster
Detection & Analysis	Identification	Alert ingestion, false-positive filtering
	Identification (cont.)	Automated enrichment, confidence scoring
Containment, Eradication & Recovery	Containment	Quarantine, domain blocking, host isolation
	Eradication	Org-wide artifact removal
	Recovery	Restoration validation, heightened monitoring
Post-Incident Activity	Lessons Learned	Metrics capture, feedback loop

The finding of note here is that NIST's single combined phase maps to three distinct SANS phases, which is the primary structural divergence identified in Section 2.1 and confirmed opera-

tionally in this mapping.

5.2 Decision Logic Validation Trace

Table 2 presents the validation trace described in Section 4.5, confirming the decision tree produces exactly one action for every tested confidence-score input.

Table 2: Decision logic validation trace across confidence-score boundaries.

Input Score	Condition Matched	Resulting Action
0	$\text{Score} < 25$	Auto-close false positive
24	$\text{Score} < 25$	Auto-close false positive
25	$25 \leq \text{Score} < 60$	Route Tier 1 review
59	$25 \leq \text{Score} < 60$	Route Tier 1 review
60	$60 \leq \text{Score} < 85$	Auto-contain (reversible); Tier 2 approval
84	$60 \leq \text{Score} < 85$	Auto-contain (reversible); Tier 2 approval
85	$\text{Score} \geq 85$	Escalate to IR Lead; full approval required
100	$\text{Score} \geq 85$	Escalate to IR Lead; full approval required

No gaps or overlaps were found at any threshold boundary (24/25, 59/60, 84/85), confirming the branching logic in Section 4.3 is exhaustive across the full 0–100 range.

5.3 Containment Action Set

Table 3 summarizes the five containment actions specified, each with an explicit trigger condition and rollback method, consistent with the auditability principle and the evidence preservation requirement in National Institute of Standards and Technology (2006).

Table 3: Containment action set with trigger conditions and rollback methods.

Action	Trigger Condition	Rollback Method
Quarantine email org-wide	Confidence $\geq$ 60	Restore from quarantine via case ID
Block sender domain/IP	Confidence $\geq$ 85 or IR Lead approval	Remove from block list
Disable malicious URL	Confidence $\geq$ 60	Re-enable if determined benign
Isolate host	Sandbox confirms execution + approval	Release after clean scan
Disable/reset account	Credential submission confirmed + approval	Re-enable after password reset and MFA re-enrollment

5.4 Communication and Metrics Structure

The finalized communication matrix defines four notification tiers (Low, Medium, High, Critical) mapped against three audiences (SOC Tier 1/2, IR Lead, Management/CISO), with SLA timers ranging from 24 hours (Low severity acknowledgment) to 15 minutes (Critical severity acknowledgment). Four metrics were defined for capture at case closure, consistent with National Institute of Standards and Technology (2012) Section 3.4: Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), number of users affected, and false-positive rate, tracked over a rolling 30-day window.

5.5 Summary of Findings

The completed playbook specification demonstrates that a phishing triage workflow can be fully decomposed into automatable stages (enrichment, scoring, low-impact containment) and human-gated stages (high-impact containment, account actions), with a clean, non-overlapping decision

boundary between the two. The dual-framework mapping (Section 5.1) additionally surfaces a structural finding: NIST's combined Containment/Eradication/Recovery phase, while sufficient for high-level compliance reporting, is insufficiently granular for specifying discrete operational procedures, which is why the SANS six-phase model was retained for that purpose throughout Sections 4 and 5.

6 Analysis and Recommendations

This section interprets the findings presented in Section 5 and states what should change or be validated as a result.

6.1 Analysis

6.1.1 Decision Boundary Robustness

The validation trace in Table 2 confirms the decision logic is exhaustive and non-overlapping at the tested boundaries. However, this validation was purely logical (manual tracing of representative inputs), not empirical, since no live alert data was available (Section 4.5). The round-number thresholds (25, 60, 85) were chosen for auditability and explainability rather than derived from historical false-positive/true-positive distributions. This is an appropriate starting position for a new playbook but represents a known limitation: thresholds calibrated without production data risk being either too conservative (excessive analyst workload from Tier 1 review) or too permissive (auto-containment on insufficiently confident cases).

6.1.2 Value of Dual-Framework Mapping

The structural divergence identified in Section 5.1 NIST's single combined phase mapping to three SANS phases has a direct practical consequence: an organization reporting compliance against National Institute of Standards and Technology (2012) alone would describe containment, eradication, and recovery as a single undifferentiated activity, obscuring the fact that these are operationally distinct stages with different validation criteria (Section 9 of the playbook specification, "Conditions for Restoring Normal Operations"). Retaining the SANS decomposition internally, while reporting against NIST terminology externally, resolves this without requiring the organization to abandon its primary compliance framework.

6.1.3 Fail-Safe Default as a Deliberate Tradeoff

The fail-safe default behaviour (Section 7.3 of the playbook specification: incomplete enrichment routes to manual review rather than the highest-confidence branch) is a deliberate tradeoff of speed

for defensibility. This is consistent with the risk-based control selection required by National Institute of Standards and Technology (2020), IR-4, but it does mean the playbook's automation benefit is reduced precisely in the cases where an enrichment source is degraded or unavailable — which may correlate with periods of genuine attack activity if an adversary is also targeting the organization's threat intelligence infrastructure. This tradeoff was judged acceptable for a first-version playbook, since the cost of an incorrect auto-remediation (per Section 7.3) is higher than the cost of a delayed manual review.

6.2 Recommendations

1. **Calibrate confidence thresholds empirically.** Once the playbook is deployed against live alert data, the 25/60/85 thresholds (Section 4.3) should be reviewed against actual false-positive and true-positive rates and adjusted via the playbook feedback loop (Section 12.2 of the playbook specification), rather than left as static round numbers indefinitely.
2. **Add a fourth threat intelligence source for redundancy.** The current design queries three sources (VirusTotal, AbuseIPDB, MISP); per National Institute of Standards and Technology (2016)'s multi-source recommendation, adding a fourth source would reduce the frequency with which the fail-safe default (Section 6.1.3) is triggered by a single source outage.
3. **Pilot the playbook in shadow mode before full deployment.** Running the playbook against live alerts without executing containment actions (logging only) for an initial period would generate the empirical data needed for Recommendation 1 without risking an incorrect automated action in production.
4. **Extend the modular sub-playbooks to other alert types.** Per the modularity design principle (Section 13.4 of the playbook specification), the enrichment and evidence-preservation sub-playbooks were designed to be reusable; a concrete next step is to pilot their reuse in a non-phishing playbook (e.g., malicious insider activity) to validate that the modularity claim holds in practice rather than only in design intent.

7 Conclusion

This project set out to design a complete, standards-referenced SOAR playbook for automated phishing incident triage, built for Splunk SOAR (Phantom). That objective was met: the resulting specification maps explicitly to both the NIST SP 800-61 Revision 2 four-phase incident response life cycle and the SANS Institute's six-phase model (National Institute of Standards and Technology, 2012; SANS Institute, 2012), defines an exhaustive, validated confidence-scored decision tree, specifies containment and recovery actions with explicit rollback methods, and embeds forensic evidence preservation consistent with National Institute of Standards and Technology (2006) ahead of any destructive containment step.

The work demonstrates that the majority of phishing triage alert ingestion, false-positive filtering, multi-source enrichment, and confidence scoring can be fully automated, while high-impact, difficult-to-reverse actions remain gated behind explicit analyst approval, consistent with the risk-based control selection required by National Institute of Standards and Technology (2020), IR-4 and IR-5. The dual-framework lifecycle mapping proved to be more than a documentation exercise: it surfaced a genuine structural finding, that NIST's combined Containment, Eradication, and Recovery phase is insufficiently granular for specifying discrete operational procedures, which shaped how Sections 4 and 5 of this report were structured.

The playbook's principal limitation, discussed in Section 6.1, is that its decision thresholds were set for auditability and explainability rather than calibrated against live alert data, since no production deployment was available for this project. The recommendations in Section 6.2 empirical threshold calibration, a fourth threat intelligence source, a shadow-mode pilot, and cross-playbook reuse of the modular sub-playbooks represent the concrete next steps required to move this specification from a validated design to a production-ready automation.

Overall, the project confirms that a rigorously standards-mapped SOAR playbook, cited by specific framework section rather than by framework name alone, provides a defensible and auditable foundation for reducing Mean Time to Detect and Mean Time to Respond in a Security Operations Center context, without sacrificing the human judgment that ambiguous or high-impact incidents require.

8 References

References

MITRE Corporation (2024), 'Mitre att&ck for enterprise', <https://attack.mitre.org>. Accessed August 2026.

National Institute of Standards and Technology (2006), Guide to integrating forensic techniques into incident response, Technical Report NIST Special Publication 800-86, U.S. Department of Commerce, Gaithersburg, MD.

National Institute of Standards and Technology (2012), Computer security incident handling guide, Technical Report NIST Special Publication 800-61 Revision 2, U.S. Department of Commerce, Gaithersburg, MD.

National Institute of Standards and Technology (2016), Guide to cyber threat information sharing, Technical Report NIST Special Publication 800-150, U.S. Department of Commerce, Gaithersburg, MD.

National Institute of Standards and Technology (2020), Security and privacy controls for information systems and organizations, Technical Report NIST Special Publication 800-53 Revision 5, U.S. Department of Commerce, Gaithersburg, MD.

SANS Institute (2012), 'Incident handler's handbook', SANS Reading Room. Accessed August 2026.